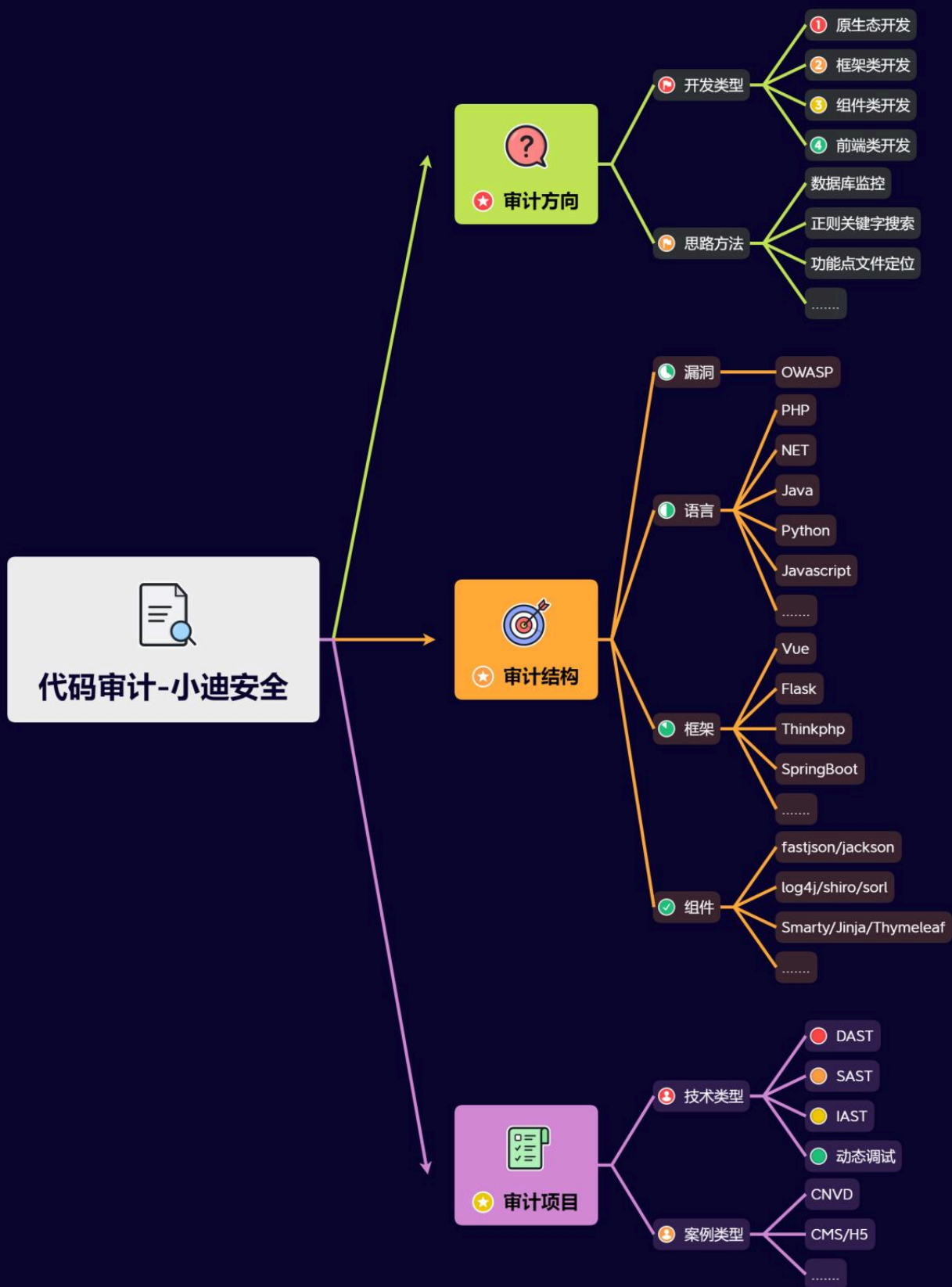


Day119 代码审计-JavaEE开发篇&身份验证鉴权 逻辑&拦截器&过滤器&Shiro框架&JWT技术



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘

-
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
 - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

-
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
 - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
-

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
 - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
 - 3、ASP.NET审计-动态调试-附加进程&断点调试
 - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
-

- 1、JavaEE审计-文件安全-上传&下载&读取&写入等
 - 2、JavaEE审计-文件安全-功能点追踪&关键字搜索
-

2.详细点

2.1 代码编辑器



- 1 一、代码编辑器：
- 2 1.Jetbrains IDEA(IDE)
- 3 2.Sublime text(文本编辑器)
- 4 3.Eclipse (IDE)

2.2 测试工具



- 1 1.Burp Suite: 是渗透测试工作者必备的一款工具
- 2 2.SwitchyOmega: SwitchyOmega 是一款代理管理插件，支持Firefox和Chrome浏览器，并支持HTTP、HTTPS、socket4和socket5协议。
- 3 3.Max HackerBar: HackBar是的一个插件，也是信息安全从业者常用的经典工具。
- 4 4.Postman: Postman是一款功能强大的网页调试工具，能够为用户提供强大的Web API & HTTP请求调试功能。
- 5 5.Ysoserial: 一款开源Java反序列化测试工具，内部集成有多种利用链，可以快速生成用于攻击的代码，也可以将新公开的反序列化漏洞利用方式自行加入Ysoserial中。
- 6 6.Marshalsec: 是一款开源的Java反序列化测试工具，不仅可以生成各类反序列化利用链，还可以快速启动恶意的RMI服务等。
- 7 7.MySQL Monitor: 是web版本的SQL记录实时监控工具。
- 8 8.Beyond Compare: 是一款文件比较工具，主要对比两个文件夹或者文件，并以颜色标示差异，比较范围包括目录、文档内容等。使用该工具可以方便代码审计人员快速地比对两个版本代码的差别。

2.3 反编译工具



1. **JD-GUI**: 是一款具有UI界面的反编译工具，界面简洁大方，使用简单方便。
2. **Fernflower**: 功能比JD-GUI更强大，虽然没有UI界面，但可以配合系统指令完成批量反编译的工作。
3. **CFR**: 功能强大的反编译工具，支持主流Java特性——Java 8 lambda表达式，以及Java 7字符串切换。在某些JD-GUI无法反编译的情况下，CFR仍然能完美地进行反编译，也可以像FernFlower那样配合系统指令进行批量反编译。
4. **IntelliJ IDEA**: 具能够自动解包已添加依赖的Jar包，并对其内容进行反编译。该工具拥有动态调试和字符串匹配和搜索功能，为审计和调试漏洞工作提供了极大便利。
5. **CodeReviewTools**: 是一款可以快速搜索代码中的关键点，一键对jar进行批量反编译，也支持直接对war包进行操作。

2.4 Java代码静态扫描工具



1. **Fortify SCA**: 获得业界认可的静态代码检查工具，但它是收费的。Fortify SCA的核心在于规则库，用户可以自定义规则库，减少误报。
2. **VCG**: 基于 VB 开发的一款windows下的白盒审计工具。VCG 支持多种语言，例如C/C++、Java、C#、VB、PL/SQL、PHP。VCG会根据代码中的变量名等信息动态生成针对该代码的漏洞规则，通过正则检查是否有和漏洞规则所匹配的代码。
3. **FindBugs与FindSecBugs插件**: FindBugs是一款Bug扫描插件，在IDEA和Eclipse中都可进行安装。FindBugs可以帮助开发人员发现代码缺陷，减少Bug，但其本身并不具备发现安全漏洞的能力，需要安装FindSecBugs拓展发现安全漏洞的能力。
4. **SpotBugs**: 是FindBugs的继任者，所以二者用法基本一样，可以独立使用，也可以作为插件使用。
5. **CheckMark**: 白盒代码审计解决方案，主要通过采用独特的词汇分析技术和CXQL专利查询技术对应用程序源码进行静态分析检查。
6. **Snyk插件**: 修复项目中的安全漏洞、基础架构错误配置和代码质量问题。
7. **Sensei插件**: 可在键入时扫描和修复易受攻击的代码 - 具有数百个可下载的安全编码配方（规则）以及内置的自行制作能力。
8. **Reshift Security插件**: 可以快速发现漏洞，提供多个代码修复片段，以及丰富的文档，涵盖了每个漏洞的检测、修复和测试。
9. **MurphySec Code Scan插件**: 可以快速识别您的项目中使用了哪些存在安全缺陷的开源组件，并帮助您一键修复问题。
10. **Momo Code Sec Inspector插件**: 重于在编码过程中发现项目潜在的安全风险，并提供一键修复能力。
11. **dependence-check**: 可用于检查已发布安全漏洞的项目依赖项。
12. **wJa**: 一款结合DAST、SAST、IAST的综合性应用程序安全分析工具，支持对java web程序的安全性进行分析，含有反编译，代码审计，调试jar包，代理追踪等用于分析软件安全的功能。
13. **tabby**: 是一款针对Java语言的静态代码分析工具，它使用静态分析框架 Soot 作为语义提取工具，将JAR/WAR/CLASS文件转化为代码属性图，并使用 Neo4j 图数据库来存储生成的代码属性图CPG。
14. **SpringInspector**: Java自动代码审计工具，尤其针对Spring框架，提供一个SpringBoot的Jar包即可进行自动代码审计，底层技术基于字节码分析。
15. **gadgetinspector**: 反序列化漏洞利用链、漏洞检测工具。

2.5 开发审计入口常见方法



- 1 -搜索法：常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
- 2 -功能法：框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
- 3 -对比法：可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
- 4 -特征法：数据库监控SQL注入，文件监控上传删除写入等，后续补充
- 5 -调试法：动态调试（PHP,ASP.NET,JavaEE,Python等）
- 6 -工具法：后续讲到（DAST&SAST&IAST&CodeQL等）

3.演示案例

3.1 JavaEE审计-身份验证-常见鉴权方法



- 1 1、搜索类别：业务关键字&相关操作类&封装关键字
- 2 2、功能点也适用，直接找鉴权技术特征目录进行代码追溯
- 3 -找有没有Interceptor，拦截器里有没有鉴权
- 4 -找有没有Filter，过滤器里有没有鉴权
- 5 -找有没有Shiro，看版本及里面的逻辑配置
- 6 -找有没有Jwt，看后面写的四个方向确定
- 7 -找以上都没有，看看是不是自写代码逻辑鉴权



- 1 **Interceptor**是一种拦截器，也称之为拦截器链（**Interceptor Chain**），主要用于拦截请求、响应或处理过程中的某些事件，比如权限认证、日志记录、性能测试等。在 **Java** 中，**Interceptor**可以用来扩展框架，增加或修改某个方法的行为，或者对应用流程做些前置处理、后置处理、环绕处理等。



- 1 **Filter**被称为过滤器，过滤器实际上就是对**web**资源进行拦截，做一些处理后再交给下一个过滤器或**Servlet**处理，通常都是用来拦截**request**进行处理的，也可以对返回的 **response**进行拦截处理。开发人员利用**filter**技术，可以实现对所有**web**资源的管理，例如实现权限访问控制、过滤敏感词汇、压缩响应信息等一些高级功能。

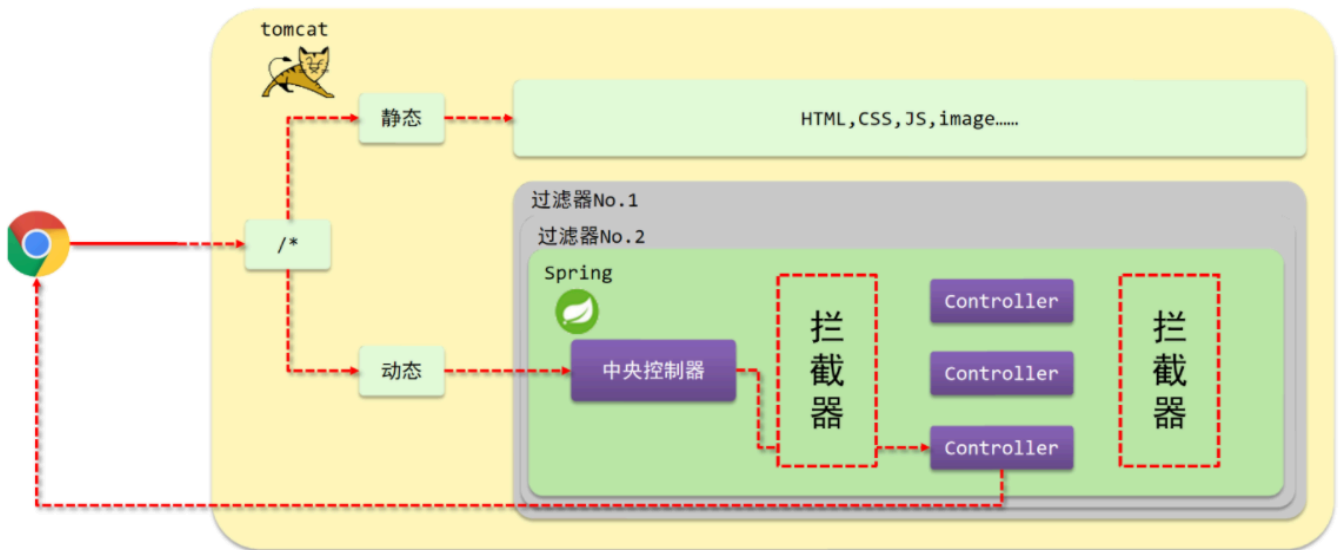


- 1 **Shiro**是一个强大且易用的**Java**安全框架,执行身份验证、授权、密码和会话管理。使用**Shiro**的易于理解的**API**,您可以快速、轻松地获得任何应用程序,从最小的移动应用程序到最大的网络和企业应用程序。



- 1 **Jwt**: **JSON Web Token**，将用户信息加密到**token**里，服务器不保存任何用户信息，只保存密钥信息，通过使用特定加密算法验证**token**，通过**token**验证用户身份。基于**token**的身份验证可以替代传统的**cookie+session**身份验证方法。这使得**JWT**成为高度分布式网站的热门选择，在这些网站中，用户需要与多个后端服务器无缝交互。

3.2 JavaEE审计-鉴权安全-拦截器&监听器



- 1 #使用Interceptor拦截器进行鉴权
- 2 案例-NewbeeMall-使用拦截器进行鉴权
- 3 下载: <https://github.com/newbee-ltd/newbee-mall>
- 4 `Interceptor->AdminLoginInterceptor->preHandle->uri.startswith`
- 5 如果路径的开头是以/admin开头并且Session中的loginUser属性为 null
- 6 利用: 构造结构路径为/;/admin或//admin后访问 (不影响解析)



- 1 #使用Filter过滤器进行鉴权
- 2 案例-华夏ERP-使用过滤器进行鉴权
- 3 下载: <https://github.com/jishenghua/jshERP>
- 4 `urlPatterns->LogCostFilter->doFilter->requestUrl,ignoredList,allowUrls`
- 5 `/login.html/../../account/getAccount`
- 6 `/xiaodi.css/../../account/getAccount`
- 7 `/user/login/../../account/getAccount`

3.3 JavaEE审计-鉴权安全-Shiro框架&JWT技术



- 1 #使用Shiro框架进行鉴权
- 2 案例-Tumo-Shiro框架鉴权
- 3 下载: <https://github.com/TyCoding/tumo>
- 4 1、引用shiro做身份验证
- 5 pom.xml Maven配置文件
- 6 `<shiro-spring-version>1.5.2</shiro-spring-version>`
- 7 2、查看shiro配置信息
- 8 anon一般代表不需要鉴权的配置，**则表示该接口下的所有接口。
- 9 `tumo.shiro.anon_url=\`
- 10 `/login,/logout,/register,\`
- 11 `/,/about,/p/**,/links,/comment/**,/link/list,/article/list,\`
- 12 `/css/**,/js/**,/img/**`

```
13 3、寻找利用点
14 CommentController.java
15 @RequestMapping("/comment")
16 @GetMapping("/{id}")
17 @DeleteMapping("/{id}")
18 4、测试
19 GET /comment/1
20 DELETE /comment/1
21 注意：除此之外还可以看下这个版本漏洞是否可以绕过
```



```
1 #使用Jwt技术进行鉴权
2 JWT审计看以下：
3 1、生成时使用空加密（逻辑代码问题）
4 2、服务端未校验签名（逻辑代码问题）
5 3、密钥默认未被修改（搭建后未修改）
6 4、密钥爆破可能性大（密钥过于简单）
7
8 案例1-FastCMS-密钥默认未被修改
9 下载：https://gitee.com/xjd2020/fastcms
10 -看数据包获取Jwt技术
11 -代码逻辑或引用Jwt包
12 createToken->AuthConfigs->secretKey->application.yml
13
14 案例2-Nacos-密钥默认未被修改
15 下载：https://github.com/alibaba/nacos/releases
16 参考：https://blog.csdn.net/qq\_50854662/article/details/129660330
17 启动：startup.cmd -m standalone
18 nacos.core.auth.plugin.nacos.token.secret.key
19 登陆时修改返回的JWT值
```